

Experiment 6: Risk Treatment and Risk Acceptance

Aim

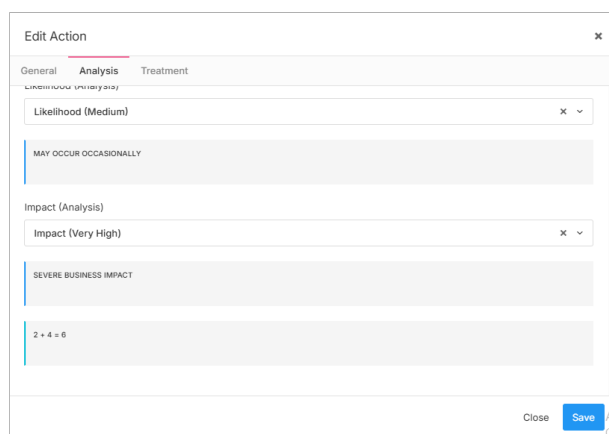
To manage identified business risks by defining suitable risk treatment plans and documenting risk exceptions using the Eramba GRC dashboard.

Procedure

1. Login to the Eramba Dashboard.
2. Navigate to **Risk Management** → **Business Risks**.
3. Select the **Business Interruption** risk.
4. Open the **Analysis** section and verify the risk assessment.
5. Review the Likelihood, Impact, and Risk Score.
6. Open the **Treatment** section.
7. Configure the risk treatment as **Accept** and associate relevant internal controls such as *Endpoint Protection*, *Backup and Recovery*, and *Firewall Management*.
8. Associate the *Information Security Policy* with the treatment.
9. Save the risk treatment configuration.
10. Navigate to **Risk Management** → **Risk Exceptions**.
11. Create/import risk exceptions with a description, requester, contact, expiration date, and status.
12. Verify the created exceptions in the Risk Exceptions register.

Output

The Business Interruption risk was analyzed with a Medium Likelihood, Very High Impact, and Risk Score of 6. Relevant controls and the Information Security Policy were associated with the risk treatment. 10 risk exceptions were also created and recorded in Eramba.



The screenshot displays the 'Edit Action' window for a risk analysis configuration. It features three tabs: 'General', 'Analysis', and 'Treatment'. The 'Analysis' tab is active, showing the following configuration:

- Likelihood (Medium)**: A dropdown menu with a value of 'Medium' and a description 'MAY OCCUR OCCASIONALLY'.
- Impact (Analysis)**: A dropdown menu with a value of 'Very High' and a description 'SEVERE BUSINESS IMPACT'.
- Risk Score**: A calculated value of '2 + 4 = 6'.

At the bottom right, there are 'Close' and 'Save' buttons.

Fig 6.1 – Risk Analysis Configuration (Likelihood: Medium, Impact: Very High, Score: 6)

Edit Action

General

Analysis

Treatment

Risk Treatment

Mitigate

×

▼

Select the current treatment for this Risk

Mitigating Business Continuity Plans

Choose one or more...

Add

No results found

Endpoint Protection

×

Backup and Recovery

×

Firewall Management

×

Add

Treatment: Policies

Information Security Policy [Policy]

×

Add

Treatment: Risk Exceptions

Add

Close

Save

Fig 6.2 – Risk Treatment Configuration & Control/Policy Association

Item detail

General

Dynamic Status

Name

ⓘ

Business Interruption

Description

A disruptive event may prevent critical business processes from operating normally.

Risk GRC Contact

Admin

Admin

Risk Originator Contact

ⓘ

Admin

Admin

Next Review Date

ⓘ

2027-08-27

Fig 6.3 – Item Detail General View (Business Interruption)

Analysis

Applicable Business Units

Operations

Processes

Threat Tags

Threat Description

Vulnerability Tags

Vulnerability Description

Risk Analysis Classification

Likelihood (Medium)

Impact (Very High)

Risk Analysis Score

6

Risk Analysis Threshold

Fig 6.4 – Risk Analysis Summary & Classification

Treatment

Risk Treatment

ⓘ

Accept

Mitigating Business Continuity Plans

Treatment Internal Controls

Endpoint Protection

Backup and Recovery

Firewall Management

Treatment Policies

Information Security Policy

Treatment Risk Exceptions

Treatment Projects

Fig 6.5 – Risk Treatment Summary (Accept & Internal Controls)

Risk Response Plan	
Risk Treatment Classification	Likelihood (Medium) Impact (Very High)
Risk Treatment Score	6
Risk Treatment Threshold	

Fig 6.6 – Risk Response Plan & Score

The screenshot shows the 'Internal Controls' register in the Eramba application. It displays a table with 10 items, each with a checkbox, a status indicator (0), a name, a description, a control operator, and a related policy. The items are: Privileged Account Monitoring, Vulnerability Scanning, Incident Response, Patch Management, Firewall Management, Backup and Recovery, Security Awareness Training, Endpoint Protection, Access Review, and Multi-Factor Authentication.

Item	Issues	Name	Description	Control Operator	Contact	Related Policies	Risks
☐	0	Privileged Account Monitoring	Privileged account activities are monitored.	Admin	Admin	Information Security Policy	
☐	0	Vulnerability Scanning	Systems are periodically scanned for vulnerabilities.	Admin	Admin	Information Security Policy	
☐	0	Incident Response	Security incidents are responded to.	Admin	Admin	Information Security Policy	
☐	0	Patch Management	Security patches are identified and applied.	Admin	Admin	Information Security Policy	
☐	0	Firewall Management	Network traffic is controlled.	Admin	Admin	Information Security Policy	
☐	0	Backup and Recovery	Critical organizational data is backed up.	Admin	Admin	Information Security Policy	
☐	0	Security Awareness Training	Personal receive information is protected.	Admin	Admin	Information Security Policy	
☐	0	Endpoint Protection	Endpoints are protected.	Admin	Admin	Information Security Policy	
☐	0	Access Review	User and privileged access is reviewed.	Admin	Admin	Information Security Policy	
☐	0	Multi-Factor Authentication	Requires an additional authentication factor.	Admin	Admin	Information Security Policy	

Fig 6.7 – Risk Exceptions Register (10 Items)

← Back

Reputation Damage Risk Exception

Item detail

General	
Dynamic Status	Missing Risk
Name	Reputation Damage Risk Exception
Description	Temporary acceptance of residual reputation risk while additional preventive measures are evaluated.
ORC Contact	Admin Admin
Exception Requester Contact	Admin Admin
Status	Open
Start Date	2026-08-27
Expiration Date	2026-09-27
Closure Date	
Related Asset Risks	
Related Third Party Risks	

Fig 6.8 – Risk Exception Item Detail View

Result

The business risk was successfully analyzed and its treatment was configured in Eramba. Risk exceptions were successfully created, configured with requesters, contacts, and expiration dates, and verified in the Risk Exceptions register.